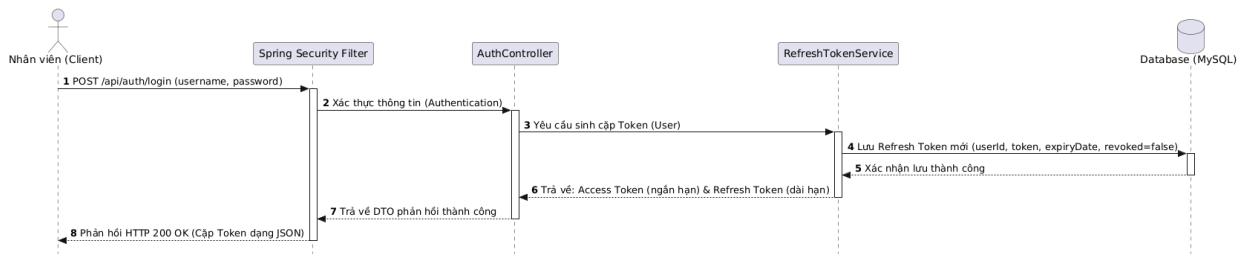
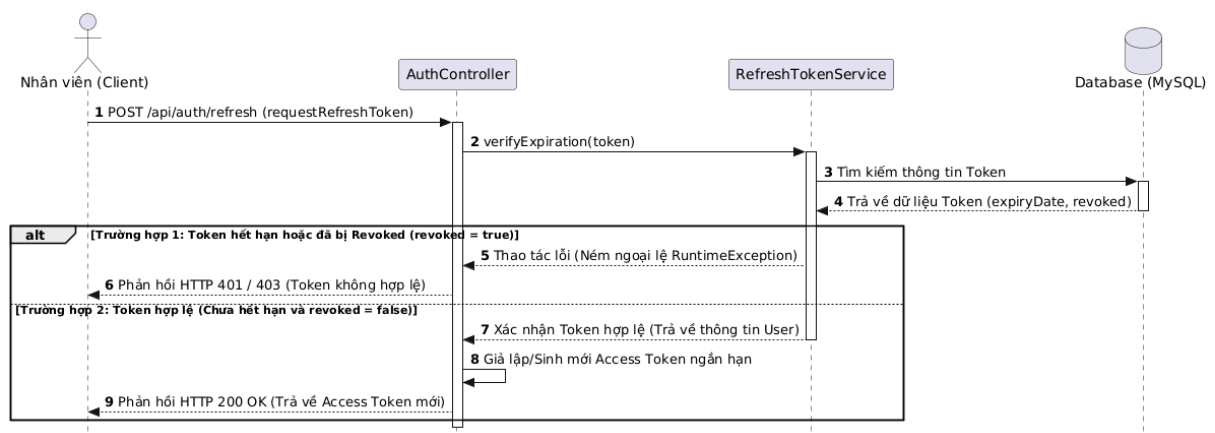


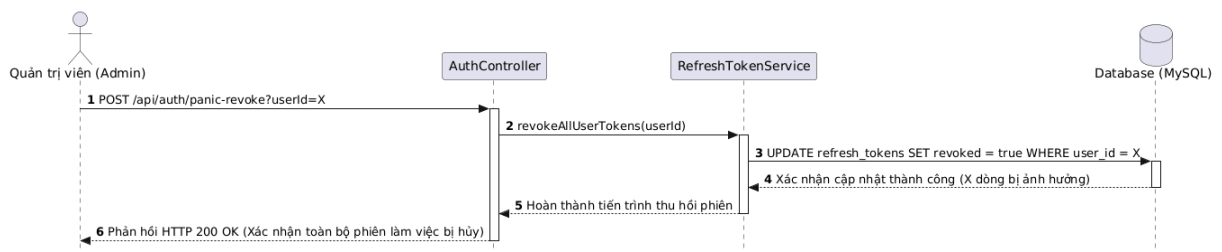
(1) Đăng nhập cấp cấp Token



2) Dùng Refresh Token đổi Access Token mới



(3) Tiến trình Revoke Token.



1. Trạng thái "Revoke" được lưu trữ ở đâu?

Hệ thống áp dụng chiến lược Lưu trữ lưỡng tính (Hybrid Storage) kết hợp giữa tính toàn vẹn dữ liệu và tốc độ:

- Lớp lưu trữ bền vững (Persistence Layer - Database): * Tại bảng refresh_tokens trong cơ sở dữ liệu quan hệ (MySQL), một trường dữ liệu kiểu Boolean tên là revoked (mặc định là false) được thiết lập.

- Khi Admin hoặc người dùng kích hoạt lệnh thu hồi quyền truy cập, hệ thống thực hiện câu lệnh UPDATE chuyển trạng thái revoked = true (hoặc xóa hẳn bản ghi tùy theo cấu hình nghiệp vụ). Điều này đảm bảo dữ liệu luôn chính xác và không bị mất ngay cả khi hệ thống gặp sự cố mất điện hoặc khởi động lại.
- Lớp lưu trữ bộ đệm (Caching Layer - Redis): *(Khuyến dùng cho môi trường sản phẩm thực tế)*
 - Khi một tài khoản bị thu hồi hoặc một token cụ thể bị đưa vào danh sách đen (Blacklist), thông tin định danh userId hoặc token đó sẽ đồng thời được đẩy vào Redis Cache dưới dạng một Key-Value.
 - Thời gian sống (TTL - Time to Live) của Key này trên Redis sẽ được cài đặt bằng đúng thời gian hiệu lực còn lại của chính Token đó để tránh làm lãng phí RAM của hệ thống cache.

2. Giải pháp kiểm tra trạng thái Revoke nhanh nhất (Tối ưu hóa hiệu năng)

Đối với hệ thống token, việc kiểm tra tính hợp lệ diễn ra liên tục với tần suất rất lớn. Nếu mỗi request gửi lên đều phải thực hiện một lệnh SELECT xuống cơ sở dữ liệu MySQL thông qua ổ đĩa cứng, hệ thống chắc chắn sẽ bị nghẽn cổ chai (Database Bottleneck). Do đó, quy trình kiểm tra tối ưu nhất được thực hiện như sau:

- Bước 1: Kiểm tra tại lớp bộ nhớ RAM (Redis Cache): * Khi JwtTokenFilter hoặc RefreshTokenService nhận được yêu cầu, hệ thống sẽ thực hiện lệnh đọc $O(1)$ trên bộ nhớ RAM của Redis để kiểm tra xem Token/User này có nằm trong Blacklist hay không. Quá trình này chỉ mất chưa tới vài mili-giây. Nếu tìm thấy dữ liệu trong Blacklist, hệ thống lập tức từ chối và trả về lỗi 401 Unauthorized.
- Bước 2: Xử lý cô lập ở tầng Token làm mới (Refresh Token):
 - Do bản chất Access Token có thời gian sống rất ngắn (5 - 15 phút), ta có thể chấp nhận để Access Token tự hết hạn mà không cần kiểm tra database liên tục ở mọi request gọi API nghiệp vụ.
 - Điểm chốt chặn quan trọng nhất là API /refresh: Tại đây, việc kiểm tra sâu xuống cơ sở dữ liệu (revoked = true) bắt buộc phải thực hiện. Khi kẻ tấn công hay nhân viên đã bị vô hiệu hóa cố tình dùng Refresh Token để xin cấp Access Token mới, hệ thống sẽ chặn đứng ngay tại đây, cắt đứt hoàn toàn khả năng duy trì phiên làm việc bất hợp pháp.